

- RAG Learning

3.6 Cyber Security

AQA GCSE Computer Science (8525) — Paper 2

3.6.1 What is Cyber Security?

Cyber security is the practice of protecting computer systems, networks, programs and data from *unauthorised access, theft, damage or disruption*. It involves technical controls (firewalls, encryption, anti-malware), procedural controls (policies, training, backups) and physical controls (locked rooms, biometric doors) working together.

Everything you have studied so far in the AQA course — algorithms, programs, data representation, computer systems and networks — creates value because it stores and moves *information*. That information has worth: personal data, banking details, medical records, exam scripts, intellectual property, national infrastructure. Whenever something has worth, someone will try to steal it, alter it, or stop the rightful owner using it. **Cyber security is the set of defences that stops them.**

Examiners expect you to be able to discuss cyber security in three overlapping groups:

- **Threats** — the things that can go wrong (malware, phishing, DDoS, insider attacks, etc.).
- **Vulnerabilities** — weaknesses in the system that a threat can exploit (weak passwords, unpatched software, untrained users, misconfigured permissions).
- **Defences** — the technical and human measures taken to prevent, detect and recover from attacks (firewalls, anti-malware, encryption, policies, backups, training).

The CIA Triad

Cyber security professionals summarise what they are protecting using the **CIA triad**. You do not need this by name for AQA, but it is a useful way to organise your thinking and to write evaluation answers:

Goal	Meaning	Example of a failure
Confidentiality	Only authorised people can read the data	A leak of customer passwords to the public
Integrity	Data is accurate and has not been altered without permission	An attacker changes exam marks in the school database
Availability	Data and services are accessible when needed	A ransomware attack locks a hospital out of patient records

Why Cyber Security Matters

The consequences of poor cyber security fall into predictable categories, and exam mark schemes reward candidates who list more than one:

- **Financial loss.** Direct theft (bank transfers, stolen card details), ransom payments, lost sales during an outage, fines from data-protection regulators (ICO fines under the UK GDPR can reach tens of millions of pounds), and the cost of recovery and forensic investigation.
- **Reputational damage.** Customers move to a competitor after a breach; stock prices fall; contracts are cancelled. Trust is slow to rebuild.
- **Operational disruption.** A hospital with locked patient records cancels operations; a factory with disabled control systems stops the production line; a school with wiped servers cannot deliver lessons.
- **Legal and regulatory consequences.** Organisations have legal duties (GDPR, Computer Misuse Act 1990, Data Protection Act 2018); breaches can trigger investigations, prosecutions, and large fines.
- **Harm to individuals.** Identity theft, fraud against personal accounts, stalking, blackmail, and psychological distress. A leak of medical records or private messages is extremely damaging even if no money changes hands.
- **National-security and safety risks.** Attacks on energy grids, transport networks, water systems and hospitals can endanger lives, not just data.

Exam Tip: A common 6–8 mark question is "Discuss the impact of a successful cyber attack on a small business." Aim for *at least three distinct impact categories* from the list above,

each developed with a sentence of explanation. Writing five lines about “they lose money” will cap you at 2 marks.

Attackers — Who Would Bother?

It is useful to have a mental model of who carries out cyber attacks, because defences differ depending on the attacker. You will not be tested on the labels, but the *motives* are fair game:

- **Cyber criminals** — motivated by money. They run phishing operations, ransomware gangs, credit-card theft, and fraud.
- **Hacktivists** — motivated by a political or social cause. They deface websites, leak documents, or launch DDoS attacks on organisations they oppose.
- **State-sponsored attackers** — motivated by intelligence gathering or sabotage. Well-funded and persistent; attack government, military, infrastructure and major companies.
- **Insiders** — employees or contractors with legitimate access who steal, damage or leak information, either deliberately (disgruntled, bribed) or accidentally (clicking a phishing link).
- **Script kiddies** — inexperienced attackers using pre-written tools for status, curiosity or mischief. Less skilled but still a threat to poorly defended systems.

3.6.2 Social Engineering

Social engineering is any attack that manipulates *people* into breaking normal security procedures, rather than attacking the technology directly. Instead of trying to guess a password or crack encryption, the attacker persuades the user to hand the password over.

Social engineering is the most successful category of attack in the real world, for one simple reason: **people are easier to fool than computers are to break**. A modern firewall, a strong encryption algorithm and a fully patched operating system can be bypassed in seconds by an employee who enters their password into a fake login page because an email told them to.

Social engineering exploits predictable human behaviour:

- **Authority.** People do what they are told by an apparent manager, IT helpdesk, police officer or bank.

- **Urgency.** Under time pressure, people skip the usual checks ("your account will be locked in 24 hours").
- **Fear.** A threatening message (fines, account suspension, legal trouble) panics people into complying.
- **Trust / familiarity.** A message that appears to come from a colleague, friend or supplier is rarely questioned.
- **Helpfulness.** Staff trained to be polite and helpful will hold a door open, read out an account number, or reset a password for a "colleague".
- **Reward.** The promise of a prize, refund, gift card, or "free" thing is a classic lure.

Blagging (Pretexting)

Blagging (also called *pretexting*) is a social-engineering attack in which the attacker *invents a scenario (a pretext)* to persuade the victim to reveal information or perform an action. It is usually carried out in person or by phone.

A classic example: an attacker phones a company switchboard, claims to be "Tom from head-office IT," and says he needs the receptionist's network password to fix a critical server fault before the director's meeting in 10 minutes. The pretext combines *authority* (IT, head office), *urgency* (10 minutes) and *fear* (the director will be angry). Well-trained staff refuse; untrained staff often hand the password over.

Another example: an attacker calls a bank impersonating a customer, claims to have lost their card, and uses publicly available details (birthday from social media, address from the electoral roll) to answer the security questions and have a replacement card posted to a new address under their control.

Phishing

Phishing is a social-engineering attack in which the attacker sends a *fraudulent message* (typically an email, but also SMS, messaging apps or phone calls) pretending to be from a trusted organisation, tricking the victim into clicking a link, opening an attachment, or revealing credentials.

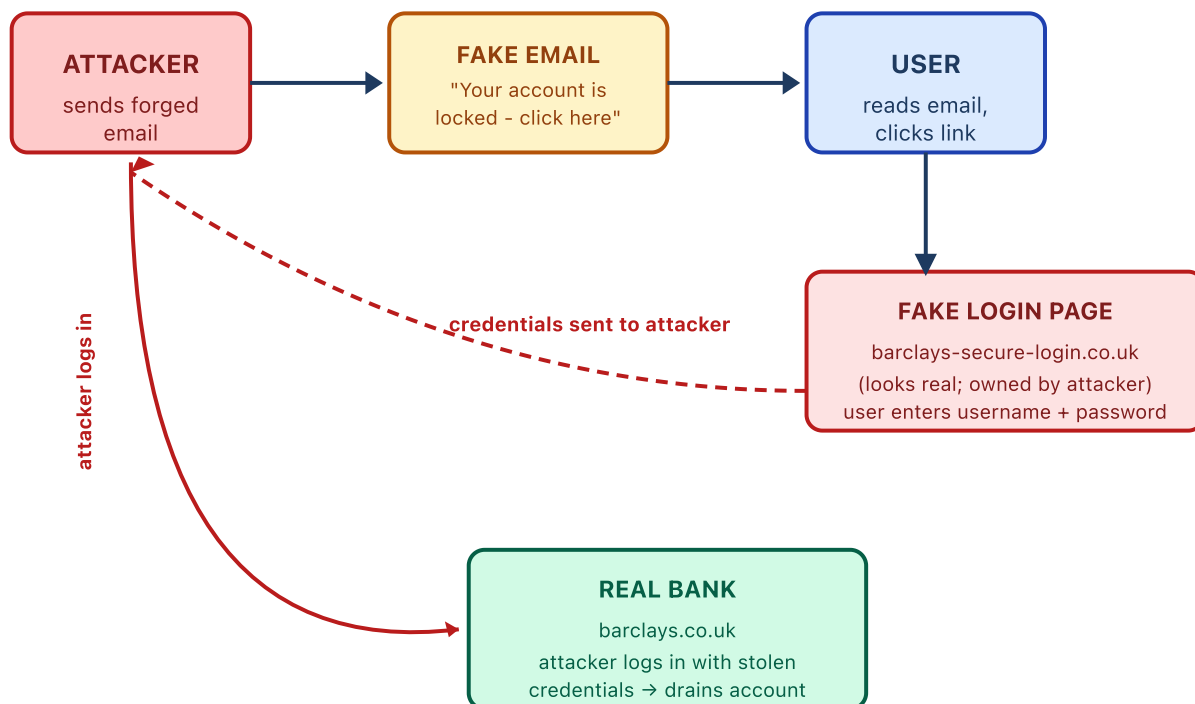
Phishing is by far the most common first stage of a real-world cyber attack. The attacker casts a wide net: millions of emails sent pretending to be from a bank, HMRC, Amazon, Microsoft 365, PayPal or similar. Even a tiny click-through rate (0.1%) yields thousands of victims.

A Typical Phishing Email

The message pretends to be from "Barclays Security", warns that the victim's account has been locked, and provides a link: `https://barclays-secure-login.co.uk/verify`. The link *looks* like Barclays but actually leads to a domain controlled by the attacker. The page is a pixel-perfect copy of the real login form; when the victim types their username and password, the attacker records them and uses them to log in to the real bank.

Phishing Attack Flow

Attacker sends fake email → user clicks link → enters credentials into fake site → attacker logs in to the real service.



Tell-tale Signs of a Phishing Email

- **Generic greeting** ("Dear customer") rather than your actual name.
- **Spelling and grammar errors** — professional organisations proof-read their messages.
- **Urgent or threatening tone** pushing you to act immediately ("your account will be closed in 24 hours").

- **Suspicious sender address** — `security@barclays-online.co` is not Barclays; the real domain is `barclays.co.uk`.
- **Suspicious links** — hover over the link; the text and the actual URL do not match.
- **Unexpected attachments**, especially `.zip`, `.exe`, `.js`, or macro-enabled Office documents.
- **Request for sensitive information** (passwords, PINs, card numbers) that a real bank would never ask for by email.

Spear-Phishing

Spear-phishing is a *targeted* phishing attack. Instead of millions of generic emails, the attacker researches one individual or small group and crafts a message just for them. A finance clerk at a law firm might receive an email that appears to come from a named senior partner they know, referencing a real client, and asking them to approve a bank transfer “urgently, before the deal closes.” Spear-phishing is harder to spot because the details check out; it is used heavily in attacks on wealthy individuals, senior executives (“whaling”) and government staff.

Pharming

Pharming is an attack that redirects a user to a fraudulent website *without their knowledge*, even when they type the correct URL. This is usually done by poisoning the DNS system or altering the victim’s local hosts file, so that `barclays.co.uk` resolves to an attacker’s IP address.

Pharming is subtle because it does not rely on a phishing email. The victim types the correct address, the browser shows the correct address, and the page looks correct — but the DNS lookup has been tampered with, so the connection actually goes to a server controlled by the attacker. The victim enters their credentials as normal, and they are stolen. Pharming is defeated in practice by correctly validated HTTPS certificates: if the attacker cannot present a valid certificate for the real domain, the browser shows a security warning.

Shouldering (Shoulder Surfing)

Shouldering (or *shoulder surfing*) is observing a person's screen or keyboard from nearby, in order to read a password, PIN, or confidential information as they type it.

Examples: someone standing behind you at a cash machine reading your PIN as you key it in; a commuter glancing at your laptop on a train and photographing the document on your screen; a CCTV camera positioned to see a checkout operator's login. Low-tech, but very effective. Defences include PIN shields on keypads, privacy screens on monitors, situational awareness (don't type passwords in public view), and multi-factor authentication (a stolen password alone is not enough).

Comparison of Social-Engineering Attacks

Attack	Channel	How it tricks the victim	Typical defence
Blagging	Phone / in person	Attacker invents a plausible pretext using authority or urgency	Staff training, call-back procedures, never give credentials over the phone
Phishing	Mass email / SMS	Fake message from a trusted brand with a link to a fake login page	User education, email filters, link checking, MFA
Spear-phishing	Targeted email	Personalised message referring to the victim's real context	Training for high-value targets, verified sender, MFA, callback on unusual requests
Pharming	Network (DNS) / hosts file	DNS tampering silently redirects real URLs to fake servers	HTTPS with valid certificates, secure DNS, anti-malware on endpoints
Shouldering	Physical proximity	Watching the screen or keyboard as the victim types	Privacy screens, PIN shields, awareness, MFA

Exam Tip: If a scenario mentions anything that relies on *manipulating a person* (ringing up pretending to be someone, clicking an email link, tricking a helpdesk, watching over a shoulder) the attack is **social engineering**. Do not write “hacking” — mark schemes reward the specific term.

3.6.3 Malicious Code (Malware)

Malware (malicious software) is any program written to damage, disrupt, gain unauthorised access to, or steal information from a computer system. It is the technical counterpart to social engineering: instead of persuading a person, the attacker runs code on a target machine.

AQA expects you to know the main families of malware, how each spreads, and the typical impact of an infection. The spec is strict about the **defining property** of each: a virus attaches to a host file, a worm self-replicates across a network, a Trojan hides inside a legitimate-looking program. Lose those properties in your answer and you will lose the mark.

Virus

A **virus** is a piece of malicious code that *attaches itself to a legitimate host file or program* and is activated when that host is run. Modern viruses attach to executables, Office documents with macros, scripts, or boot records. Once running, the virus executes its payload (deleting files, corrupting data, logging keystrokes) and attempts to infect further files on the same machine and on shared storage.

Key features: (a) requires a host, (b) requires human action to spread (the user must run the infected file or open the infected document), (c) can damage, corrupt or steal data when the payload triggers.

Worm

A **worm** is self-replicating malware that *spreads by itself across a network* without needing a host file or user action. It exploits a software vulnerability (for example, an unpatched bug in the

operating system's network services) to copy itself to other machines on the same network, each of which then scans for more vulnerable targets. Because a worm spreads automatically, it can infect thousands of machines in minutes.

Real-world example: *WannaCry* (2017) was a ransomware worm that hit the NHS and thousands of other organisations within hours by exploiting an unpatched Windows SMB vulnerability.

Trojan (Trojan Horse)

A **Trojan** is malware that *pretends to be a legitimate and useful program*, so that the user is tricked into running it. It does not self-replicate, but once run, it delivers a hidden payload — often opening a “back door” that lets the attacker control the machine remotely. Trojans are commonly distributed as cracked games, fake “video player” updates, fake invoices, or free utilities downloaded from untrusted websites.

Ransomware

Ransomware is malware that *encrypts the victim's files with a key only the attacker knows* and then displays a ransom demand (usually in cryptocurrency) offering to restore access. Modern strains also threaten to publish the stolen data if payment is refused (“double extortion”). A single successful ransomware infection can put a hospital, council or school out of action for weeks. The best defence is *good offline backups* (so you can restore the data instead of paying) combined with rapid patching, anti-malware and user education to prevent the initial infection.

Spyware

Spyware is malware that *secretly monitors the user's activity* and sends the information back to the attacker. It can log keystrokes, capture screenshots, steal saved passwords from browsers, watch webcam feeds, and track browsing history. It usually installs quietly as part of a Trojan or as a drive-by download from a malicious website.

Adware

Adware is software that *displays unwanted adverts* (pop-ups, injected banners, redirected searches) to make money for the attacker. Mild adware is merely annoying; serious adware tracks browsing behaviour to build a profile and often comes bundled with spyware.

Keylogger

A **keylogger** is a specific type of spyware that *records every keystroke* the user makes and sends the log to the attacker. Passwords, card numbers, private messages and emails all pass through the keyboard, so a keylogger on a single workstation can compromise everything the user does. Keyloggers can be software (installed by other malware) or hardware (a small device plugged in between the keyboard and the computer, used in physical attacks).

Comparison Table of Malware Types

Type	Defining feature	How it spreads	Typical impact
Virus	Attaches to a host file or program	User runs the infected file (email attachment, USB, shared drive)	Corrupts or deletes data; spreads to other files
Worm	Self-replicating; needs no host	Automatically across a network via a software vulnerability	Huge, fast outbreaks; network congestion; delivers further payloads
Trojan	Disguised as a useful program	User is tricked into installing it	Creates a back door; lets attacker control the machine remotely
Ransomware	Encrypts files and demands payment	Phishing email / worm / Trojan drops the payload	Files inaccessible; business halted; ransom demand; data leak threat
Spyware	Silently monitors user activity	Bundled with Trojans / drive-by downloads	Passwords, messages and documents stolen
Adware	Displays unwanted adverts	Bundled with free software or via malicious websites	Annoyance, slowdown, possible tracking, possible spyware bundle

Keylogger	Records every keystroke	Software (via other malware) or hardware (physical device)	Every password, message or card number typed is captured
-----------	-------------------------	--	--

Exam Tip: For a 2-mark “State one difference between a virus and a worm” question, give the *defining property*: “A virus attaches to a host file and needs a user to run it, whereas a worm is standalone and spreads automatically across a network.” That answer will score both marks every time.

3.6.4 Other Threats

Not all threats involve social engineering or malware. The AQA specification also covers attacks on passwords, attacks on availability, attacks via input data, attacks on data in transit, and attacks from inside the organisation.

Brute-Force Attacks

A **brute-force attack** systematically tries *every possible password or key* until the correct one is found. For a 4-digit PIN that is only 10 000 attempts; for a good password it is astronomically many more.

Brute force works well against weak passwords and short PINs, especially if the system does not limit how many attempts can be made per second. It is defeated by (a) long, complex passwords, (b) locking an account after a small number of failed attempts, (c) rate-limiting and CAPTCHA on login forms, and (d) multi-factor authentication, which makes the password alone useless even if it is eventually guessed.

Dictionary Attacks

A **dictionary attack** is a smarter brute-force attack that tries *common passwords and words from a dictionary* first (plus predictable variants such as “Password1”, “qwerty”, “Liverpool!”, seasons and years). Real attackers use dictionaries of millions of leaked passwords. A brute-force attack

that tried `aaaa` , `aaab` , `aaac` ... would take forever to reach “password” — a dictionary attack tries it on iteration 1.

Attack	Tries	Speed	Defences
Brute force	Every possible combination	Slow against long passwords	Long passwords, account lockout, rate limit, MFA
Dictionary	Common words / leaked passwords first	Very fast against weak or reused passwords	Forbid common passwords, enforce complexity, MFA

Denial of Service (DoS)

A **denial-of-service (DoS) attack** aims to make a computer system or network *unavailable to legitimate users* by overwhelming it with traffic or requests. The target does not have its data stolen — it is simply stopped from working.

Common techniques include flooding a web server with so many requests per second that it cannot respond to genuine users, sending malformed packets that crash the server, or exhausting a resource such as database connections or bandwidth.

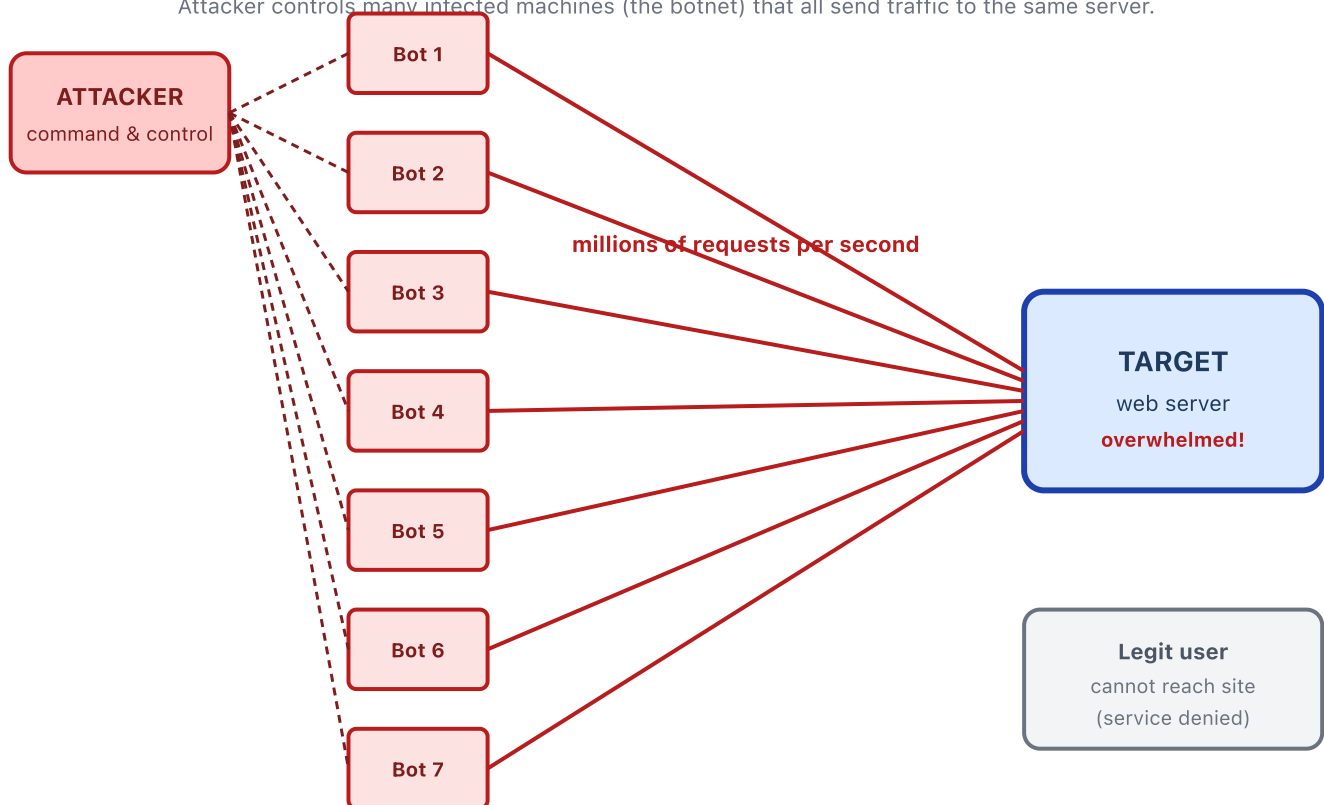
Distributed Denial of Service (DDoS)

A **distributed denial-of-service (DDoS) attack** is a DoS attack in which the flooding traffic comes from *many different compromised machines at once* — a **botnet** of computers, routers and IoT devices that the attacker secretly controls.

DDoS is far harder to block than DoS because the malicious traffic is spread across thousands of IP addresses, many of which look like ordinary home users. A DDoS attack on an e-commerce site during a big sale can cost hundreds of thousands of pounds per hour in lost revenue. Defences include DDoS-protection services that absorb and filter traffic upstream, rate limiting at the firewall, and over-provisioning of bandwidth.

DDoS Attack — Botnet Floods a Target

Attacker controls many infected machines (the botnet) that all send traffic to the same server.



SQL Injection

SQL injection is an attack in which the attacker enters *SQL code into a form or URL field* on a badly-written website. If the website pastes the user's input directly into a database query without checking it, the attacker's SQL is executed on the database — allowing them to read, change or delete data they were never supposed to see.

Example: a login form builds the query `SELECT * FROM users WHERE name = '<input>' AND password = '<input>'`. If the attacker types `' OR '1'='1` in both the name and password fields, the query becomes `SELECT * FROM users WHERE name = '' OR '1'='1' AND password = '' OR '1'='1'`, which matches every user and logs the attacker in as the first account. You will meet SQL properly in topic 3.7 — for now just remember **validated / sanitised input and parameterised queries** prevent injection.

Data Interception and Theft

Data interception (also called *eavesdropping* or a *man-in-the-middle attack*) is an attack in which the attacker captures data as it travels across a network. On an open Wi-Fi network in a café, unencrypted traffic can be read by anyone with free tools. If the data is sent over plain HTTP, sent in an unencrypted email, or typed into a login page that isn't using HTTPS, the attacker can read or modify it. The countermeasure is **encryption in transit** (HTTPS/TLS for the web, WPA2/WPA3 for Wi-Fi, VPNs for public networks).

Insider Threats

An **insider threat** comes from someone who already has legitimate access to the system — an employee, contractor, volunteer or ex-employee whose credentials have not been revoked. They are especially dangerous because they can bypass perimeter defences without raising alarms. Insider threats can be *malicious* (a disgruntled employee stealing client data to take to a competitor) or *accidental* (a busy nurse clicking a phishing link). Defences include the *principle of least privilege* (users get only the access they need), separation of duties, access logging and auditing, prompt account deactivation when people leave, and user education.

3.6.5 Identifying Vulnerabilities

A **vulnerability** is a weakness in a system that can be exploited by a threat. Threats exist regardless — vulnerabilities are the open doors that let threats succeed.

Many successful attacks do not rely on exotic techniques; they walk through open doors. The AQA spec lists the vulnerabilities you must be able to identify and explain.

Weak and Default Passwords

Many users still choose obvious passwords ("123456", "password", their pet's name) or reuse the same password across many sites. Many networked devices (routers, IP cameras, printers, IoT doorbells) ship with *default credentials* such as `admin` / `admin` that users never change. The Mirai botnet famously recruited hundreds of thousands of IoT devices simply by trying a list of default usernames and passwords.

Unpatched Software

Every piece of software has bugs, some of which are security vulnerabilities. Once the vendor publishes a patch, attackers race to exploit machines that have not yet applied it. WannaCry (2017) spread mainly through Windows machines that had not applied a patch released two months earlier. Keeping operating systems, applications and firmware up to date — preferably using *automatic updates* — is one of the single most effective defences.

Misconfigured Access Rights

A user, share or database is given more access than they need — for example, every employee being a local administrator, a public-facing cloud storage bucket being left open to the internet, or a shared folder that should be read-only being writable by all staff. The *principle of least privilege* says each user or process should have *only* the permissions required for its job, so that if one account is compromised, the damage is limited.

Removable Media

USB flash drives, external hard drives and memory cards bypass perimeter defences by travelling physically. Malware can be copied onto a USB stick, which an unaware employee plugs into a company computer, infecting it. Famously, researchers showed that a large proportion of USB sticks “dropped” in a car park were picked up and plugged in by finders. Defences: disable USB ports where not needed, automatic scanning of removable media, and staff policies that forbid using unknown devices.

Unsecured Wireless Networks

Wireless signals leak out of buildings. An open or poorly-secured Wi-Fi network can be joined by anyone nearby, who can then attack the internal LAN, intercept traffic, or use the network as a launchpad for further attacks. Using the outdated WEP standard, or WPA2 with a weak pre-shared key, gives only a thin veneer of security. Modern networks should use WPA2 or WPA3 with a strong key, hide the admin interface, disable WPS, and ideally separate guest devices onto their own isolated VLAN.

Other Common Vulnerabilities

- **Untrained users** who fall for phishing or share passwords.
- **No backups or untested backups** that cannot be restored when needed.

- **No logging or monitoring** so attacks go unnoticed.
- **Shared or orphaned accounts** that continue to work after staff leave.
- **Physical security gaps** — unlocked server rooms, unattended workstations, unshredded documents.

Exam Tip: "State two vulnerabilities..." questions want *specific* weaknesses, not threats. "Weak passwords" or "unpatched OS" is a vulnerability; "malware" is a threat. A threat-and-vulnerability pair is the heart of many mark schemes: *a brute-force attack (threat) succeeds because the user chose a weak password (vulnerability)*.

3.6.6 Methods of Protection (Technical)

Technical protection is everything you can enforce with hardware and software. No single measure is enough — a well-defended system layers several.

Passwords and Password Policies

Passwords remain the most common form of authentication. A good **password policy** tells users and systems what a valid password must look like and how to manage it:

Rule	Why
Minimum length (typically 12–16+ characters)	Makes brute-force attacks impractical
Mixture of upper, lower, digits, symbols	Increases the size of the search space
No dictionary words or obvious personal data	Defeats dictionary attacks
Different password per site	One breach does not compromise every account
Account lockout after failed attempts	Stops brute-force attacks in their tracks

Stored as salted hashes, never plain text	A database leak does not reveal the passwords
Password managers encouraged	Lets users have long, unique, random passwords without memorising them

Modern guidance (e.g. NCSC) now *discourages* forced periodic changes because they tend to produce weaker, predictable passwords ("Summer2024!" → "Autumn2024!"). Strong, unique passwords combined with **multi-factor authentication** are preferred.

Biometric Authentication

Biometric authentication identifies a user by a *physical characteristic*: fingerprint, face, iris, retina, voice or typing rhythm.

Biometrics are convenient (nothing to remember), hard to share, and hard to copy at a distance. Most modern phones and laptops use a fingerprint or face scanner for unlock. Drawbacks include: false positives / false negatives, privacy concerns about storing biometric templates, inability to change your fingerprint if the database is stolen, and the fact that a determined attacker can sometimes fake biometrics (latex fingerprints, photos). Biometrics are usually combined with a PIN or password for stronger authentication.

CAPTCHA

A **CAPTCHA** ("Completely Automated Public Turing test to tell Computers and Humans Apart") is a challenge designed to be easy for humans and hard for bots — such as "click all the traffic lights" or reading distorted text. CAPTCHAs are placed on login pages, sign-up forms and comment forms to prevent automated brute-force attacks, automated account creation and automated spam.

Email Confirmation

Email confirmation requires a new user to click a link sent to the email address they signed up with, before the account becomes active. It verifies that the user actually owns that email address,

cuts down on fake accounts, and means that the site has a working address for password-reset links. Two-factor codes sent by email are a weaker (but still useful) form of MFA.

Automatic Software Updates

Automatic software updates mean the operating system and applications apply security patches as soon as they are released, without waiting for the user to act. This is the simplest and most effective single defence against worms, because the vulnerability the worm relies on is patched before the user even hears about it. Critical on laptops, phones, servers *and* IoT devices.

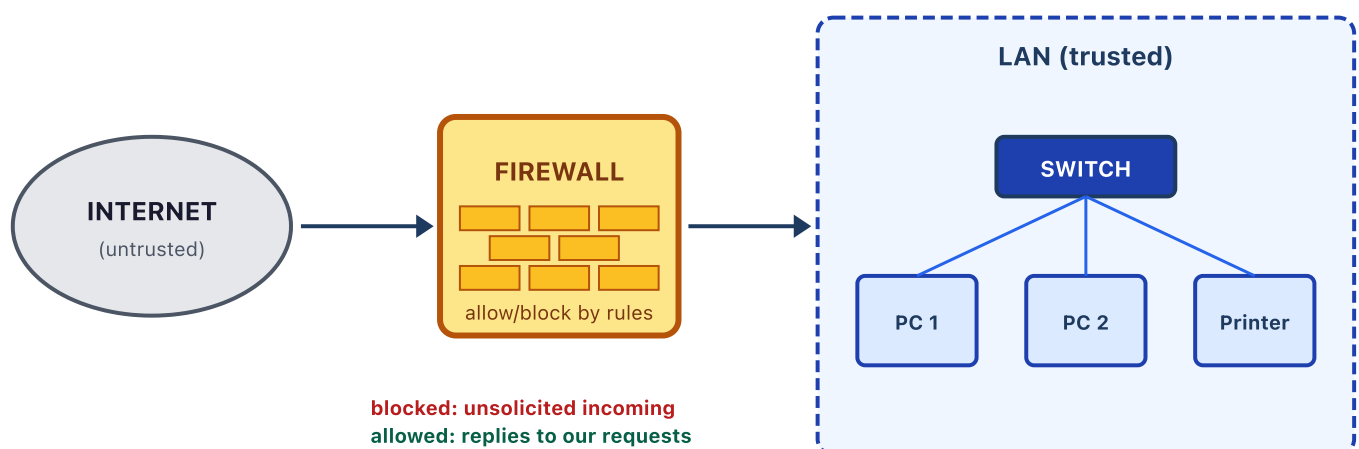
Firewalls

A **firewall** is a hardware or software barrier that sits between a trusted network and an untrusted one (typically the LAN and the internet). It inspects every packet that tries to cross and *allows or blocks* it according to a set of rules.

A typical home router includes a firewall that, by default, allows connections initiated from inside the LAN out to the internet but blocks all connections initiated from the internet into the LAN. This means a user's web browser can fetch a page, but a random attacker on the internet cannot reach their PC directly. Corporate firewalls have much richer rules, filtering by IP address, port, protocol and time of day.

Firewall Positioning

The firewall sits between the untrusted internet and the trusted LAN, inspecting every packet.



Anti-Malware Software

Anti-malware (often still called *antivirus*) software scans files, memory and network traffic for known malware. It uses:

- **Signature matching** — comparing files against a database of known malware fingerprints. Fast and accurate but only catches known threats.
- **Heuristic analysis** — looking for suspicious behaviour (a program encrypting many files, modifying system settings, or connecting to unusual servers). Can catch unknown malware but may false-positive.
- **Real-time protection** — scanning every file as it is opened, downloaded, or attached.

Anti-malware must be **kept up to date** — new malware appears by the thousand every day, so an unpatched antivirus database is almost useless. This is one of the big advantages of cloud-based scanning: lookups happen against an up-to-the-minute shared database.

User Access Levels and Permissions

A good system grants users only the access they need (*principle of least privilege*). In a school:

- Students can log in, save to their own home folder, read shared resources, and nothing else.
- Teachers can additionally read class folders and upload to them.
- Office staff can read (but not write) student records.
- Only one or two IT administrators can create accounts, install software, or change system settings.

If a student's password is stolen, the attacker can only access a student-level account — the damage is contained. This is a defence against both external attackers and insider threats.

Encryption

Encryption scrambles plaintext into ciphertext using a key. Only someone with the correct decryption key can recover the plaintext. Encryption protects data *in transit* (moving across a network) and *at rest* (stored on a disk).

Encryption in transit stops interception by attackers on intermediate networks. Everyday examples: HTTPS / TLS for web pages (indicated by the padlock icon and `https://`); WPA2/WPA3 for Wi-Fi; VPNs that encrypt everything between a device and a VPN server.

Encryption at rest stops stolen disks from yielding readable data. Everyday examples: full-disk encryption on laptops (BitLocker, FileVault) so a stolen laptop is useless without the password; database encryption; encrypted backups. Without at-rest encryption, a stolen laptop or lost backup tape can leak everything it contained.

Penetration Testing

Penetration testing ("pen testing") is the authorised practice of *attempting to break into an organisation's own systems*, using the same techniques a real attacker would, in order to find vulnerabilities before the real attackers do.

Penetration tests are carried out by professionals (in-house or hired consultants), produce a report of findings, and are followed up with a plan to fix the weaknesses. Types include *black-box* (tester knows nothing about the target, simulating an external attacker), *white-box* (tester has full information, simulating an insider), and *grey-box* (mixture). Regular pen-testing is a key part of being "secure by design" and is often required by regulators and by large customers.

Technical Protections — Summary Table

Protection	Protects against	Limitation
Strong password policy	Brute-force and dictionary attacks	Users reuse or write down complex passwords
Biometrics	Shouldering, stolen passwords	Cannot be changed if compromised; false accept/reject rates
CAPTCHA	Automated brute-force, spam accounts	Poor accessibility; modern AI can often solve them
Email confirmation	Fake accounts	Only as secure as the email account itself

Automatic updates	Worms, known vulnerabilities	Occasional bad update can break systems; doesn't help against zero-days
Firewall	Unsolicited external connections	Does not stop attacks that use allowed channels (e.g. HTTPS to a compromised site)
Anti-malware	Known malware, suspicious behaviour	Misses very new or highly targeted malware; needs frequent updates
Access levels	Insider misuse, privilege escalation	Useless if everyone is an admin; overhead to manage
Encryption	Interception in transit; theft at rest	Useless if keys are poorly managed or leaked
Penetration testing	Unknown vulnerabilities	Only a snapshot; expensive; findings must actually be fixed

3.6.7 Methods of Protection (Human and Procedural)

No technology can save a system whose users hand over their passwords, whose staff leave laptops on trains, or whose backup tapes have never been tested. Security is at least half a *human* problem, and the AQA spec requires you to be able to discuss human and procedural defences as well as technical ones.

User Education and Training

Regular, relevant training teaches staff to:

- Recognise phishing emails and report them rather than click.
- Create strong, unique passwords (ideally with a password manager).
- Lock their screens when they leave their desks.
- Never plug in unknown USB devices.
- Challenge strangers in restricted areas ("tailgating").
- Report security incidents quickly and without fear of blame.

Training is most effective when it is short, frequent, role-specific, and reinforced by simulated phishing tests rather than a one-off annual presentation.

Regular Backups

A **backup** is a copy of data kept separately from the live system, so that the data can be restored after loss, corruption or ransomware. Good backups are the single most important defence against ransomware.

The widely-used **3-2-1 rule** says: keep at least 3 copies of the data, on at least 2 different types of media, with at least 1 copy *off-site* (or offline/air-gapped). Backups should be tested regularly by actually restoring from them — a backup that has never been restored should not be trusted.

Backup type	What is copied	Pros	Cons
Full	Everything	Simple to restore — single backup contains all data	Slow to create; uses most storage
Incremental	Only changes since the last backup (any type)	Small, fast	Restore needs the last full plus every incremental in order
Differential	Changes since the last <i>full</i> backup	Restore needs only last full + last differential	Grows over time; more storage than incremental

Separation of Duties

Separation of duties means no one person has complete control over a sensitive process. For example, one employee can raise a payment request but a second employee must approve it; the database administrator cannot also audit the database logs for their own activity. This prevents fraud and means that an insider attacker needs to collude with at least one other person, which is much less likely.

Acceptable Use Policy (AUP)

An **acceptable use policy** is a document all staff and students sign that sets out what they are and are not allowed to do with the organisation's IT. Typical clauses: no personal use during work hours, no installing unauthorised software, no sharing accounts, no accessing inappropriate content, reporting lost devices within a stated time. A signed AUP gives management a basis for disciplinary action and makes expectations explicit.

Secure by Design

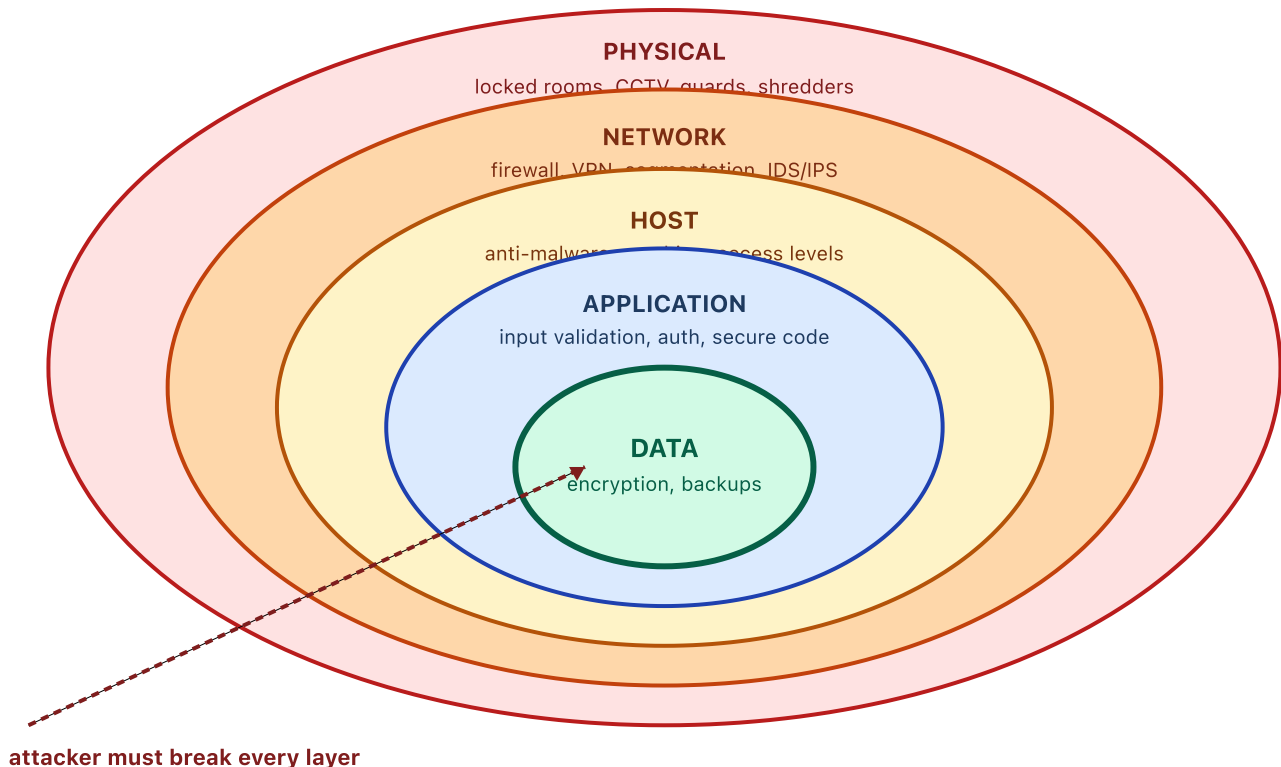
Secure by design means building security in from the start of a project, not bolting it on afterwards. Practices include: threat modelling early in the design, choosing safe defaults (encryption on, ports closed), validating all inputs, writing tests for security cases, using tried-and-tested libraries rather than hand-rolling cryptography, and carrying out penetration testing before release. Systems designed this way have far fewer vulnerabilities than those where security was an afterthought.

Defence in Depth

The overall philosophy is **defence in depth**: use several independent layers of protection, so that if one fails, others stand. A layered model looks like the onion diagram below: each layer protects different assets against different threats, and an attacker must break through all of them to reach the crown jewels (the data). This is why it is a weak answer to say "a firewall will stop all cyber attacks" — a firewall is one layer, and every serious attacker has techniques to bypass it.

Defence in Depth

Multiple independent layers — attacker must defeat every layer to reach the data.



3.6.8 Applying Protection: Worked Scenarios

Exam papers (especially Paper 2) love scenario questions where you must read a short description of an organisation, identify the threats, and recommend layered defences. The mark scheme always rewards candidates who tie specific defences to specific threats and who include *both* technical and human measures. Three worked examples follow.

Scenario 1 — A Secondary School Network

Context: A secondary school has around 1 400 students and 150 staff. The network holds student records, exam marks, safeguarding files, parent contact details, and all teaching materials. Students bring their own phones; staff use school-issued laptops at home; the school also has public Wi-Fi for visitors.

Likely threats:

- Students attempting unauthorised access to exam results, teacher files or each other's accounts.
- Phishing emails targeting staff for payroll or safeguarding data.
- Ransomware spreading from an infected USB stick or email attachment.
- Weak or shared passwords among students and staff.
- Guest Wi-Fi users pivoting onto the internal network.
- Staff laptops lost or stolen outside school.

Recommended defences:

- *User access levels* — separate student, teacher and admin roles; students cannot see each other's files or any staff area.
- *Strong password policy* combined with multi-factor authentication for staff, especially for remote access.
- *Firewall* at the school's internet connection and a separate VLAN for guest Wi-Fi isolated from the staff network.
- *Automatic software updates* pushed to every managed laptop and server.
- *Anti-malware* on every endpoint, with real-time scanning of downloads and USB devices.
- *Full-disk encryption* on staff laptops so that a lost or stolen machine does not leak safeguarding data.
- *Regular backups* using the 3-2-1 rule, with at least one copy off-site, tested termly by actually restoring a sample.
- *Acceptable use policy* signed by staff and students; *training* in phishing awareness for all staff.

Scenario 2 — A Small Online Shop

Context: A small family-run online shop sells handmade craft goods, processing about 200 orders a week. The website takes names, addresses and card details (via a third-party payment processor), and the business stores an order history, a customer mailing list, and a stock database.

Likely threats:

- Phishing emails to the owners requesting fake "supplier" bank-transfer changes.
- SQL injection on the website's search and login forms.

- Brute-force / credential-stuffing attacks on customer accounts using leaked passwords from elsewhere.
- DDoS attack during a seasonal sale.
- Data interception on unsecured Wi-Fi if the shop's owners work in cafes.
- Ransomware that encrypts product photos and the order database.

Recommended defences:

- *HTTPS/TLS* across the whole site (not just the checkout page) to defeat interception.
- *Input validation and parameterised database queries* to block SQL injection.
- *CAPTCHA* and *account lockout* on login to block brute-force attacks.
- *MFA* on the admin account used to manage the store and on the business email.
- *DDoS protection* via the hosting provider or a service such as Cloudflare.
- *VPN* for the owners when working on public Wi-Fi.
- *Regular backups* of the product database and order history, stored off-site.
- *Email confirmation* and *strong password policy* for customers to reduce fake accounts.
- *Use a reputable payment processor* so the shop never stores raw card numbers itself — reducing the scope of any breach.

Scenario 3 — A Hospital

Context: A hospital network holds patient medical records, prescribing systems, diagnostic imaging, staff rosters, and links to regional NHS services. An outage can affect patient safety — not just data.

Likely threats:

- Ransomware attacks that disable patient-record access.
- Targeted phishing aimed at senior clinicians with administrative access.
- Insider threats from thousands of staff with varying access needs.
- Unpatched medical devices that cannot easily be updated.
- Data theft leading to GDPR breaches on highly sensitive health data.
- Shouldering on busy wards where screens are in public view.

Recommended defences:

- *Network segmentation* to keep medical devices, administrative systems and guest Wi-Fi strictly apart.
- *Least-privilege access* — nurses, doctors, admin and IT each get the minimum access their role needs, with *auditing* on every access to sensitive records.
- *MFA* for every remote and administrative login.
- *Automatic patching* for everything patchable, and isolation of devices that cannot be patched.
- *Encryption at rest* on all patient databases and *encryption in transit* for all data moving between systems.
- *Regular, tested, offline backups* that ransomware cannot reach.
- *Privacy screens* and automatic screen lock for ward workstations; *staff training* in shouldering awareness.
- *Separation of duties* between clinical, administrative and IT-admin roles; prompt account deactivation when staff leave.
- *Incident-response plan* with drills, so the hospital can switch to paper procedures and continue to treat patients if systems go down.

Exam Tip: In scenario questions the mark scheme typically requires at least one *technical* defence (e.g. encryption, MFA) *and* at least one *human/procedural* defence (e.g. staff training, backups, acceptable use policy). Write your answer as pairs: "Threat X is countered by Defence Y because..." — it maps neatly onto the marking grid.

Threat → Defence Matrix

Threat	Main technical defences	Main human / procedural defences
Phishing / spear-phishing	Email filters, browser warnings, MFA, DMARC/SPF	Staff training, reporting culture, simulated phishing
Malware (virus, worm, Trojan)	Anti-malware, firewall, automatic updates, least privilege	Training (don't run unknown files), USB policy, AUP

Ransomware	Anti-malware, patching, MFA on remote access, network segmentation	3-2-1 tested offline backups, incident-response drills
Brute-force / dictionary attacks	Strong password policy, account lockout, CAPTCHA, MFA	Password-manager training, password audit
DoS / DDoS	DDoS-mitigation service, rate limiting, over-provisioned bandwidth	Incident plan, communication template for outages
SQL injection	Input validation, parameterised queries, WAF	Developer training, code review, penetration testing
Data interception	HTTPS/TLS, WPA2/WPA3, VPN, end-to-end encryption	Training (avoid public Wi-Fi for sensitive tasks)
Insider threat	Least-privilege access, auditing, separation of duties, DLP tools	Vetting, leavers process, AUP, culture of reporting
Shouldering	Screen auto-lock, privacy filters, PIN shields, MFA	Awareness training, workspace layout
Lost / stolen device	Full-disk encryption, remote wipe, strong login	Policy for reporting losses promptly

The Four-Word Summary of 3.6

If you only remember four things from this topic:

1. **Threats** combine *social engineering* (phishing, blagging, pharming, shouldering) and *technical attacks* (malware families, brute force, DoS/DDoS, SQL injection, interception, insider threats).
2. **Vulnerabilities** are the open doors: weak passwords, unpatched software, misconfigured access, removable media, unsecured wireless, untrained users.
3. **Defences** come in two halves — *technical* (firewalls, encryption, MFA, anti-malware, updates, access levels, CAPTCHA, pen-testing, email confirmation, biometrics) and *human / procedural* (training, backups, separation of duties, AUP, secure-by-design).
4. No single defence is enough — layer them (**defence in depth**), and expect the exam to ask you to map specific defences to specific threats.

If you can confidently explain each of those bullet points with a one-sentence example, you can answer almost anything 3.6 can throw at you.